DESIGN AND APPLY CONTEXT-AWARE ACCESS CONTROLS BASED ON USER IDENTITY.

Project Title:

Design and apply context-aware access controls based on user identity report format abstract.

Program : Naan Mudhalvan

Course : Cyber Security

Team Members:

Member 1 – A.Akalya & 2326J1526

Member 2 – K.Dheebankumar & 2326J1527

Member 3 – S.Gayathri & 2326J1528

Member 4 – D.Ramya & 2326J1536

Member 5 – V.Karnan & 2326J1531

Institution: Cheran Arts Science College

Guide: Mrs.M.Jeevitha

Date: 08/03/2026

INTRODUCTION:

In modern digital environments, protecting sensitive information and resources has become a major challenge for organizations. Traditional access control systems mainly rely on verifying a user’s identity, such as through usernames and passwords, to determine whether access should be granted or denied. However, these methods alone are no longer sufficient to handle advanced security threats and dynamic working environments like remote work, cloud services, and mobile computing.

Context-aware access control is an advanced security approach that enhances traditional access control mechanisms by considering additional contextual information when making access decisions. In addition to verifying the user’s identity, this approach evaluates factors such as the user’s location, device type, time of access, network conditions, and behavior patterns. By analyzing these contextual elements, the system can dynamically adjust permissions and provide more secure and flexible access management.

Designing context-aware access control systems helps organizations ensure that only authorized users can access specific resources under appropriate conditions. For example, an employee may be allowed to access company data from an office network during working hours but may require additional authentication when accessing the system from an unknown location or device.

This report focuses on the design and application of context-aware access controls based on user identity. It also explores different use case scenarios to demonstrate how contextual factors can improve security, reduce unauthorized access, and support efficient access management in modern information systems.

If you want, I can also give the **Objectives, Methodology, Use Case Scenarios, and Conclusion sections** to complete the **full report**.

Context-aware access control is a modern security approach that manages access to systems and data based on **user identity and contextual information**. Traditional access control methods mainly verify a user's identity through usernames and passwords. However, with the growth of cloud computing, mobile devices, and remote work, additional factors are needed to improve security.

In context-aware access control, the system evaluates various context factors such as **user location, device type, time of access, and network conditions** along with the user's identity. Based on these conditions, the system decides whether to **grant, deny, or limit access** to resources.

ABSTRACT:

Context-aware access control is an advanced security approach used to protect systems and sensitive information by evaluating multiple contextual factors before granting access. Traditional access control systems rely mainly on usernames and passwords, which may not be sufficient to prevent modern cyber threats. To improve security, context-aware access control considers additional factors such as user identity, device posture, location, and application risk level. By analyzing these factors, the system can make more intelligent decisions about whether a user should be allowed to access a particular resource.

The primary objective of designing and applying context-aware access controls based on user identity is to ensure that only authorized users can access specific systems or applications under secure conditions. User identity plays a critical role in authentication and authorization processes. Once the identity of the user is verified, the system evaluates other contextual parameters such as whether the device used is secure and compliant, whether the access request comes from a trusted location, and whether the application being accessed has high security requirements.

In this approach, device posture assessment ensures that the device used for login meets the organization's security policies, including updated operating systems, antivirus protection, and firewall configurations. Location-based access control helps detect suspicious login attempts from unknown or high-risk geographic regions. Application risk evaluation allows organizations to apply stricter security policies to sensitive applications that store critical data. These combined checks provide an additional layer of protection against unauthorized access and cyber attacks.

During the implementation process, several steps are followed, including preparation, configuration, scanning, vulnerability identification, reporting, remediation, and regular follow-up scanning. Security tools and monitoring systems are used to identify vulnerabilities such as weak authentication mechanisms, access from untrusted locations, unmanaged devices, and missing multi-factor authentication. Proper solutions are then implemented to strengthen the system's security policies.

By implementing context-aware access control, organizations can significantly reduce security risks and protect their critical systems and information assets. This approach supports modern security frameworks such as Zero Trust Architecture and helps maintain a strong and flexible access control environment. Overall, context-aware access control based on user identity plays an important role in improving cybersecurity and ensuring safe access to digital resources.

Use Case Scenarios :

1. Introduction

Context-aware access control is a security approach that grants or restricts access to resources based not only on **user identity** but also on **contextual information** such as location, device type, time of access, and behavior patterns.

Traditional access control models only verify **who the user is**, but modern systems also consider **where, when, and how the user is accessing the system**.

This method improves **security, privacy, and risk management** in organizations.

---

2. Objectives

The main objectives of context-aware access control are:

- Ensure **authorized users access only permitted resources**
- Reduce risks from **unauthorized or suspicious access**
- Adapt access permissions based on **dynamic context**
- Improve **organizational security policies**

- 1. Design of Context-Aware Access Control (Based on User Identity)

Step 1: User Identification

The system first identifies the user through authentication methods such as:

Username and password
Biometric authentication (fingerprint, face ID)
Smart card or token
Multi-Factor Authentication (MFA)

Step 2: Identity Verification

The system verifies whether the user is valid by checking identity in:

Identity management database
Active Directory or authentication server

Step 3: Role Assignment

Each user is assigned a **role** that determines permissions.

Example roles:

Admin – Full system access

Employee/User – Limited access to personal information

Step 4: Context Evaluation

The system evaluates the context such as:

User identity
Access time
User privileges
Security policies

Step 5: Access Decision

Based on policies and identity:

Allow access

2. Architecture / Components

A User – Person requesting access
Authentication System – Verifies identity
Policy Engine – Applies access control policies
Context Analyzer – Checks user identity and other factors
Resource Server – Provides the requested data or service

---

3. Use Case Scenarios

Scenario 1: College Management System

User: Student, Faculty, Admin

User Identity	Access Permission
Student	View marks and attendance
Faculty	Upload marks and manage courses
Admin	Manage students, faculty, and system settings

Scenario 2: Hospital Information System

User Identity	Access
Doctor	View and update patient medical records
Nurse	View patient details but cannot change diagnosis
Patient	View their own reports only

Example:
A **doctor** can edit patient treatment details, but a **patient cannot modify records**.

Scenario 3: Company Network Access

User: Employee, HR Manager, IT Admin

User Identity	Access
Employee	Access personal files
HR Manager	Access employee records
IT Admin	Access server and system settings

Output:

Designing and applying context-aware access controls based on user identity is a security approach that allows or denies access to systems and resources by considering both the identity of the user and the surrounding context of the access request. In this method, the system first verifies the user’s identity through authentication methods such as usernames, passwords, or biometric verification. After confirming the identity, the system evaluates additional contextual factors like location, device type, time of access, and network environment. Based on predefined security policies, the system then decides whether the user should be granted or denied access. This approach improves security because access decisions are not based only on identity but also on real-time conditions, reducing the risk of unauthorized access. Context-aware access control is widely used in modern technologies such as cloud computing, enterprise networks, and Internet of Things (IoT) systems to provide flexible, intelligent, and secure resource management.

The implementation of context-aware access control based on user identity provides an effective way to enhance system security and manage access to sensitive resources. In this system, access decisions are not made solely based on user identity but also consider various contextual factors such as location, device type, time of access, and network conditions. By combining identity verification with contextual information, the system ensures that users can access resources only under appropriate and secure conditions.

When a user attempts to access a system or application, the system first verifies the user's identity through authentication methods such as usernames, passwords, or multi-factor authentication. After confirming the identity, the system evaluates contextual factors related to the access request. These factors may include whether the user is accessing the system from an authorized location, whether the device used is recognized or secure, and whether the request is made during permitted access hours.

If all the contextual conditions satisfy the predefined access control policies, the system grants the user permission to access the requested resources. However, if the system detects unusual or unauthorized conditions, such as access from an unknown device or suspicious location, it may either deny access or request additional verification steps. This dynamic decision-making process helps reduce the risk of unauthorized access and potential security breaches.

The implementation of context-aware access control also improves flexibility in managing access permissions. Different users may have different roles and privileges, and the system can adjust access levels based on both the user’s identity and the current context. For example, an employee may have full access to certain resources within the organization’s network but limited access when connecting from outside the network.

STAGE–1

Title:

Design and apply context-aware access controls based on user identity ,device posture, location, and application risk.

Overview :

Context-aware access control is a security approach that dynamically decides whether a user should access a system or application based on multiple real-time factors rather than relying only on a username and password. The model evaluates **user identity**, **device posture**, **location**, and **application risk level** before granting or restricting access. First, **user identity verification** ensures that the person requesting access is authenticated using methods such as multi-factor authentication (MFA), biometric verification, or identity federation. Second, **device posture assessment** checks whether the device being used meets security requirements, such as having updated operating systems, active antivirus protection, encryption, and compliance with organizational security policies. Third, **location awareness** analyzes where the access request originates, allowing or blocking access depending on whether the user is connecting from trusted networks, approved geographic regions, or unusual locations. Finally, **application risk classification** determines the sensitivity of the application or data being accessed and applies stricter controls for high-risk systems, such as financial platforms or confidential databases. By combining these contextual factors, organizations can implement adaptive policies that allow normal access under safe conditions while requiring additional verification or blocking access when risks increase. This approach improves security, reduces the chances of unauthorized access, and supports modern zero-trust security strategies by continuously evaluating trust throughout a session rather than granting permanent access after a single login

Context-aware access control is a modern security approach that dynamically manages user access tosystems and data based on multiple contextual factors instead of relying only on usernames and passwords. In traditional acccontrol systems, once a user is authenticated, they are often granted broad access regardless of their environment or device condition. However, with the growth of cloud computing, mobile devices, and remote work environments, organizations require more intelligent and adaptive security models. Context-aware access control addresses this need by evaluating factors such as **user identity, device posture, location, and application risk** before granting or restricting access.

User identity is the primary component of context-aware access control. It verifies who the user is through authentication mechanisms such as passwords, multi-factor authentication (MFA), biometric verification, or identity management systems. Access permissions are assigned based on the user’s role, responsibilities, and privileges within the organization. For example, an administrator may have higher access privileges than a regular employee.

List of Teammates :

S.no	name	college	contact
1	Akalya.A	Cheran arts science college	8144758224
2	Dheeban kumar.K	Cheran arts science college	9025200265
3	Gayathri.S	Cheran arts science college	6369288963
4	Ramya.D	Cheran arts science college	9791868508
5	Karnan.V	Cheran arts science college	8428428479

List of Vulnerability :

S. No.	Vulnerability Name	CWENo.
1.	Improper Access Control	CWE-284
2.	Improper Authentication	CWE-287
3	Incorrect Authorization	CWE-863
4.	Overly Permissive Access Control	CWE-732
5.	Reliance on IP Address for Authentication	CWE-291
6.	Improper Privilege Management	CWE-269

Report:

1. Vulnerability name: Improper Access Control CWE: 284

OWASP category -: Improper Access Control **-OWASP Top 10 A07:2021 – Identification and Authentication Failures**.
Improper Access Control
1. CWE (Common Weakness Enumeration)

- **CWE-284: Improper Access Control**

These CWE entries describe weaknesses where an application fails to properly restrict users from accessing resources or actions.

---

2. OWASP Category

- **OWASP Top 10 (2021): A01 – Broken Access Control**

This category includes vulnerabilities where users can act outside their intended permissions, such as viewing or modifying other users' data.

---

3. Description

Improper Access Control occurs when an application does not correctly enforce restrictions on authenticated or unauthenticated users. This allows attackers to access sensitive data, perform unauthorized actions, or modify system resources.

Access control should ensure that users can only access data and functions for which they are authorized.

---

4. Business Impact

Data Breach: Sensitive information like customer records may be exposed.

- **Financial Loss:** Unauthorized transactions or manipulation of financial data.
- **Reputation Damage:** Loss of customer trust and brand reputation.
- **Legal Issues:** Non-compliance with regulations such as GDPR or HIPAA.
- **Operational Disruption:** Attackers may change or delete critical data.

---

5. Vulnerability Path

Example vulnerable endpoint:

https://example.com/account/view?user_id=102

If the system does not verify that the logged-in user owns user_id=102, another user could change the parameter to access other accounts.

Example attack:

https://example.com/account/view?user_id=101

---

6. Vulnerability Parameter

Typical parameters that may lead to improper access control:

- user_id
- account_id
- role
- admin
- file_id
- order_id

Example:

GET /profile?user_id=105

If authorization checks are missing, an attacker can change the value.

---

7. Steps to Reproduce

1. Log in to the application as a normal user.
2. Navigate to a page that contains a parameter such as user_id.
3. Intercept the request using a proxy tool like **Burp Suite**.
4. Modify the parameter value (e.g., change user_id=105 to user_id=106).
5. Forward the request to the server.

6. If another user's data is displayed, the application has **Improper Access Control**.

---

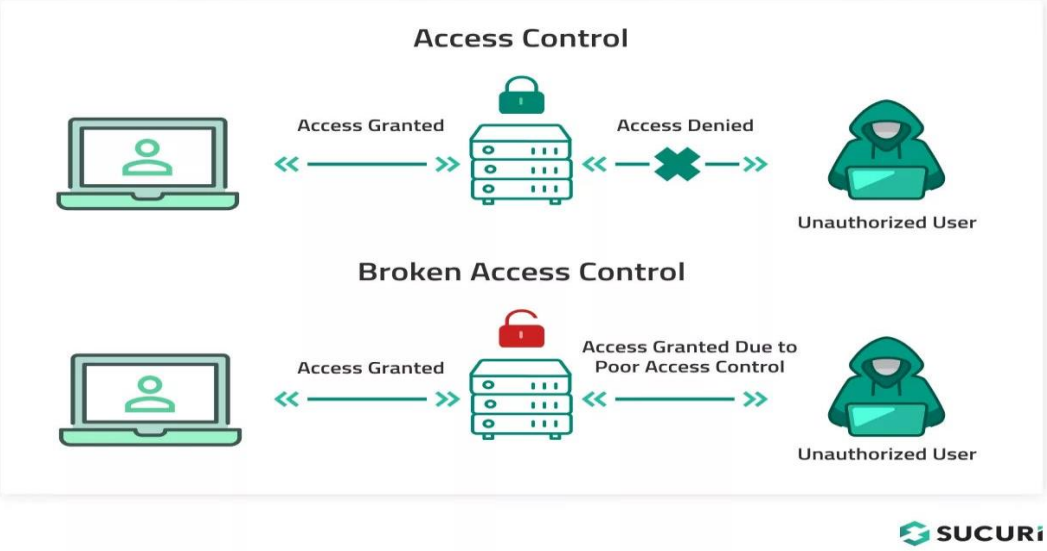
8. Example Request
GET /api/user/profile?user_id=101 HTTP/1.1
Host: example.com
Cookie: session=abcd1234

Modified request:

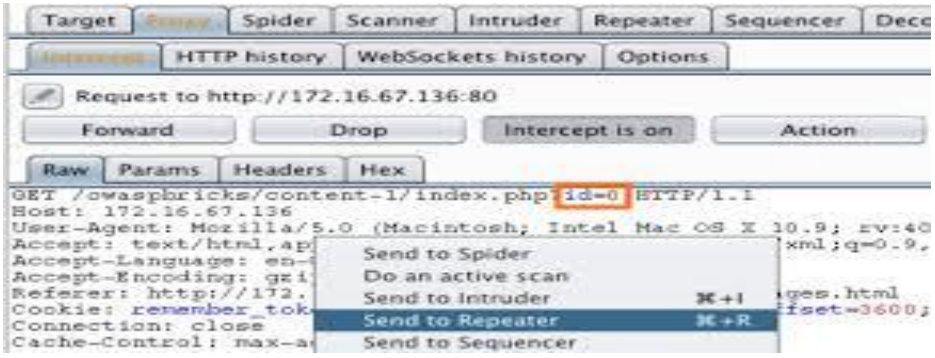
GET /api/user/profile?user_id=102 HTTP/1.1
Host: example.com
Cookie: session=abcd1234

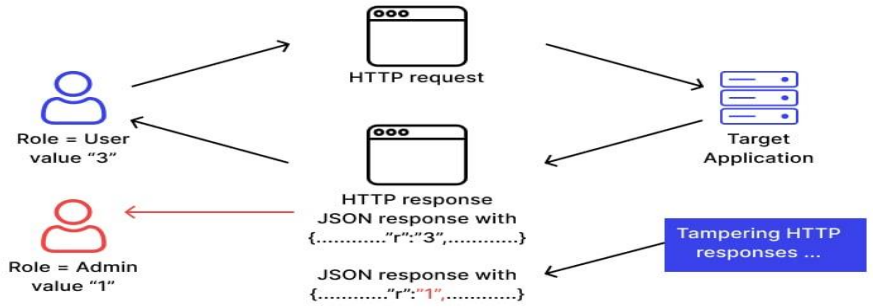
---

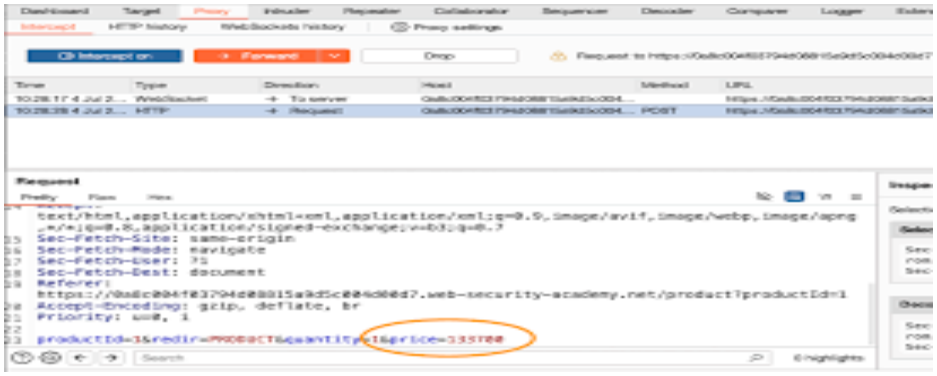
9. Images (Example)
Access Control Bypass Concept



Parameter Manipulation Example:







If you want, I can also help you convert this into a **proper vulnerability report format (for college assignment or penetration testing report)** with **title page, diagrams, and references**.

2. Vulnerabilityname: Improper Authentication

CWE: 287

Description :

Improper Authentication occurs when a system fails to properly verify the identity of a user, device, or system before granting access to resources. This vulnerability allows attackers to bypass authentication mechanisms such as login pages, API authentication, or session validation.

Common causes include:

- Weak authentication logic
- Missing authentication checks
- Default credentials

- Poor session management
- Direct access to restricted URLs without login

Business Impact

Improper Authentication can cause serious damage to an organization, including:

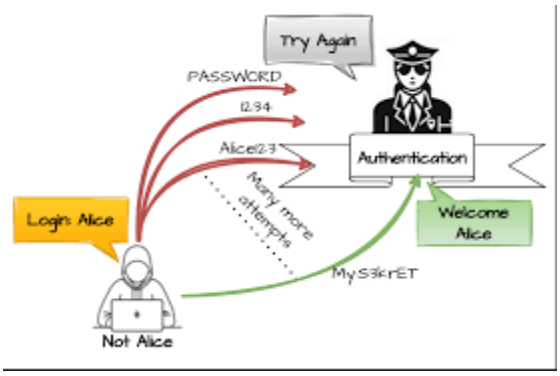
- **Unauthorized access** to sensitive user accounts
- **Data breaches** involving confidential information
- **Account takeover attacks**
- **Financial loss** and fraud
- **Loss of customer trust and brand reputation**
- **Legal or regulatory penalties**

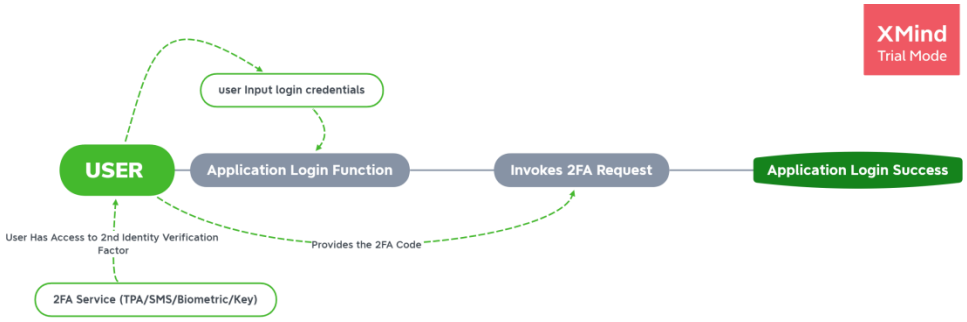
Vulnerability Path

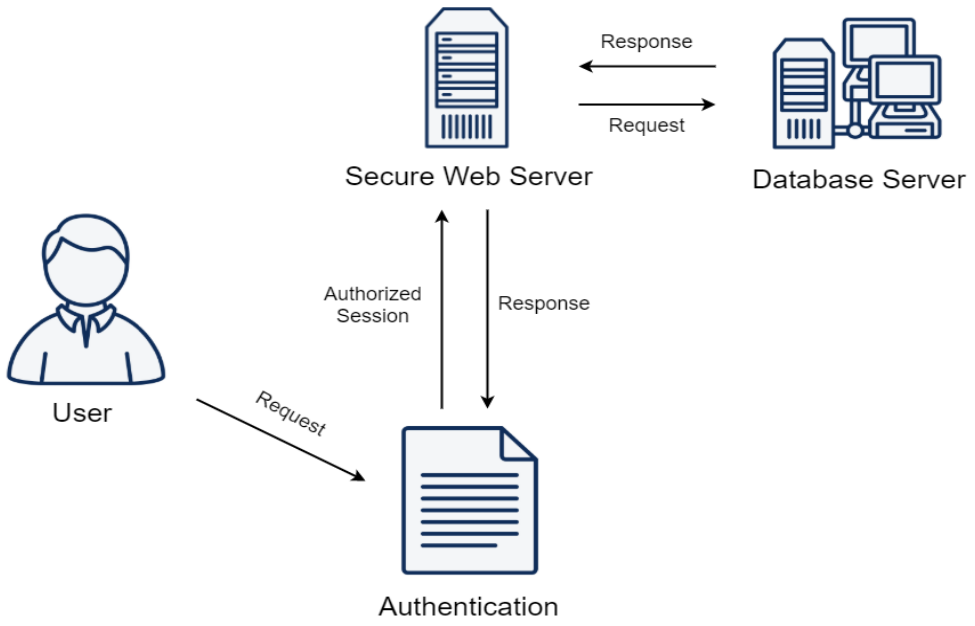
Example vulnerable endpoint:

https://example.com/admin/dashboard

If authentication is not properly enforced, an attacker may directly access this path without logging in.



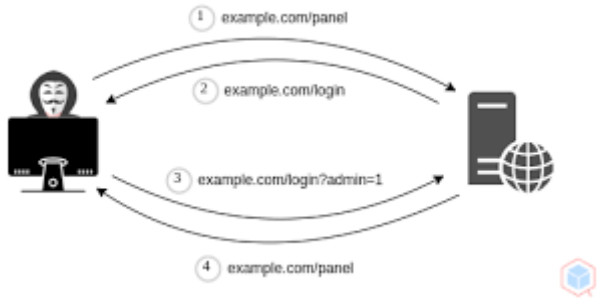




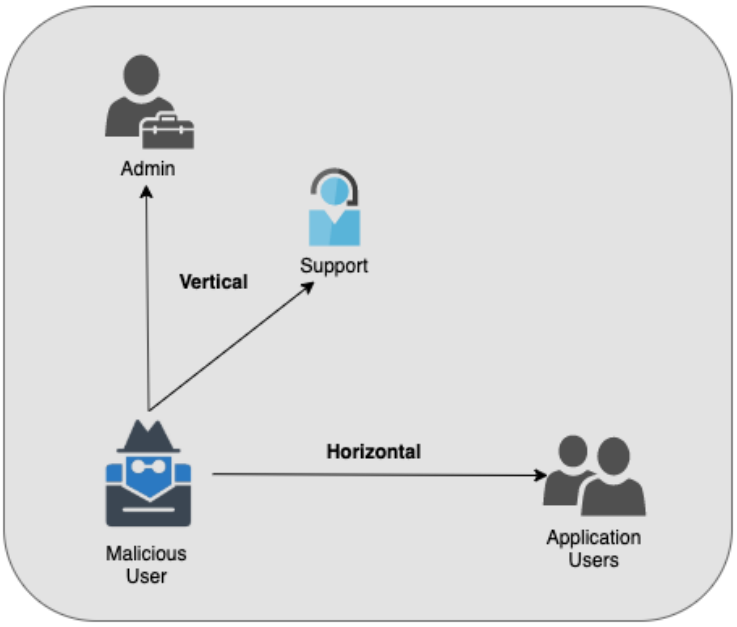
3. Vulnerability name: Incorrect Authorization

CWE: 863

Incorrect Authorization (Improper Authorization)



Broken Access Control



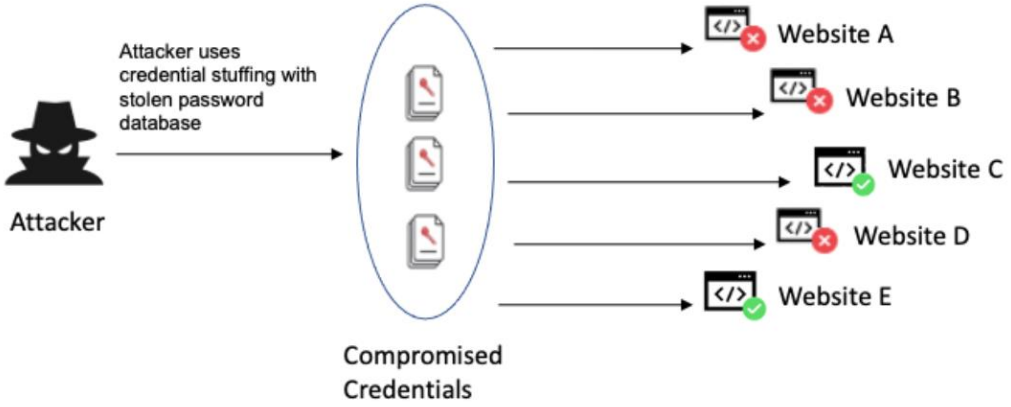


Figure: Identification and authentication failures attack scenario

Topic

Incorrect Authorization / Improper Authorization

CWE

CWE-285

OWASP Category

OWASP Top 10 A01:2021 Broken Access Control

Description

Incorrect Authorization occurs when an application fails to properly verify whether an authenticated user has permission to access a specific resource or perform a specific action.

Even though the user is logged in, the system does not correctly check **access rights**. As a result, attackers can access resources that should be restricted.

Common causes include:

- Missing authorization checks
- Improper role validation
- Direct access to restricted URLs
- Insecure API access control
- Manipulation of user IDs or role parameters

Example:
A normal user accessing an **admin dashboard** by directly entering the URL.

Business Impact

Incorrect Authorization can lead to serious organizational risks:

- Unauthorized access to sensitive data

- Exposure of confidential user information
- Privilege escalation attacks
- Unauthorized modification or deletion of data
- Financial loss and fraud
- Damage to brand reputation and customer trust

Vulnerability Path

Example vulnerable endpoint:

https://example.com/admin/panel

or

https://example.com/api/user/details

If authorization checks are not implemented properly, a normal user can directly access admin resources.

Vulnerability Parameter

Example parameters that may be manipulated:

role
user_id
account_id
access_level

Example request:

https://example.com/account?user_id=102

An attacker may change:

user_id=102 → user_id=103

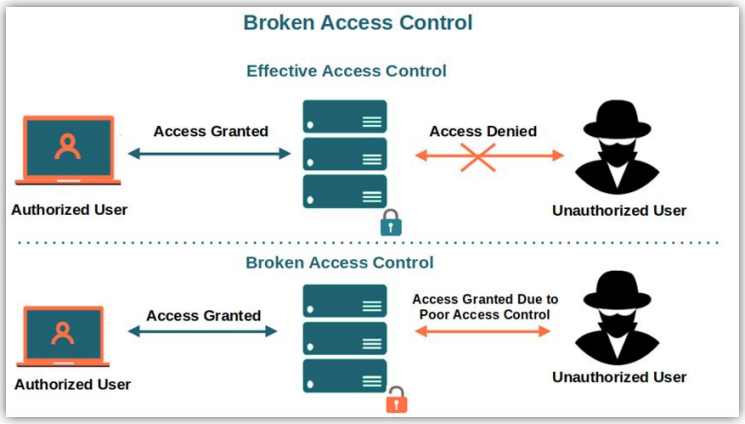
to view another user's account information.

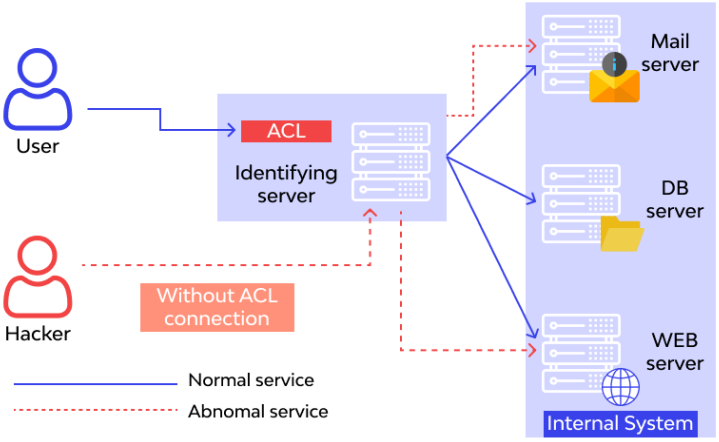
Steps to Reproduce

1. Open the target web application.
2. Login as a **normal user account**.
3. Capture the request using a proxy tool like **Burp Suite**.
4. Identify requests containing parameters such as user_id, role, or account_id.
5. Modify these parameters to access other users’ data or admin functionality.
6. Send the modified request to the server.
7. If the server returns unauthorized data without proper permission checks, the vulnerability exists.

4. Vulnerability name: Overly Permissive Access Control

CWE: 732





Topic

Overly Permissive Access Control

CWE

CWE-284 – Improper Access Control
(Also related: **CWE-732 – Incorrect Permission Assignment for Critical Resource**)

OWASP Category

A01:2021 – Broken Access Control from the OWASP Top 10.

Description

Overly Permissive Access Control occurs when an application grants users more permissions than necessary. The system fails to properly restrict access to resources based on user roles or privileges.

In this situation, normal users may be able to:

- Access admin panels
- View or modify other users' data
- Perform privileged actions such as deleting or updating records

This vulnerability typically occurs because of:

- Missing authorization checks
- Misconfigured role-based access control (RBAC)
- Direct object reference without permission validation
- Incorrect file or API permissions

Business Impact

The impact of overly permissive access control can be severe for organizations:

- **Unauthorized data access** to sensitive user information
- **Data modification or deletion** by unauthorized users
- **Privilege escalation attacks**
- **Financial and operational losses**
- **Violation of compliance regulations**
- **Damage to company reputation and customer trust**

Vulnerability Path

Example vulnerable endpoint:

https://example.com/admin/users

A normal user may access this URL directly even though it should only be available to administrators.

Another example:

https://example.com/api/deleteUser

Vulnerability Parameter

Common vulnerable parameters include:

role
user_id
account_id
isAdmin
permission

Example request:

https://example.com/profile?user_id=102

If the application does not verify ownership, changing the user_id value may allow attackers to access other users' profiles.

5. Vulnerability name : Reliance on IP address for authentication

CWE: 291

Topic

Reliance on IP Address for Authentication

OWASP Category

A07:2021 – Identification and Authentication Failures from the **OWASP Top 10.**

Description

Reliance on IP address for authentication occurs when an application grants access to users based solely on their IP address instead of using strong authentication mechanisms. In this vulnerability, the system assumes that requests coming from a trusted IP address are legitimate. However, attackers can bypass this control by spoofing or manipulating IP addresses, using VPNs, proxies, or compromised systems within the trusted network. As a result, unauthorized users may gain access to sensitive systems or data.

Business Impact

- Unauthorized users may gain access to restricted systems.
- Sensitive company data can be exposed or modified.
- Attackers may bypass login mechanisms and perform malicious activities.
- Loss of customer trust and reputation damage.
- Possible financial losses or legal compliance issues.

Vulnerability Path

Example path where the vulnerability may exist:

Application → Login / Admin Panel → Access Control Check → IP Validation → Access Granted

If the system checks **only the IP address** without verifying the user identity, the vulnerability occurs.

Example:

https://example.com/admin

Access is allowed if the request comes from a **whitelisted IP address**.

Vulnerability Parameter

Common parameters involved:

- X-Forwarded-For
- Client-IP
- Remote-Addr
- True-Client-IP

Attackers may manipulate these headers to **fake their IP address**.

Example request:

```
GET /admin HTTP/1.1
Host: example.com
X-Forwarded-For: 192.168.1.100
```

Steps to Reproduce

1. Identify a page that allows access based on IP authentication (e.g., admin panel).
2. Intercept the request using a proxy tool (such as **Burp Suite**).
3. Modify the request header X-Forwarded-For.
4. Insert a trusted or whitelisted IP address.
5. Forward the request to the server.
6. If the server grants access without login, the vulnerability exists.

Example Images (Conceptual)

1. Normal Request

User → Server
IP: 10.10.10.15
Access: Denied

2. Spoofed Request

Attacker → Proxy Tool → Server
Header: X-Forwarded-For: 192.168.1.10 (Trusted IP)
Access: Granted

3. Vulnerability Flow

User Request
↓
Check IP Address
↓
IP in Whitelist?
↓
Yes → Access Granted

6.VULNERABILITY NAME **:** Improper Privilege Management

Topic

Improper Privilege Management

CWE

CWE-269 – Improper Privilege Management

OWASP Category

OWASP Top 10: A05 – Security Misconfiguration / A01 – Broken Access Control

Description

Improper Privilege Management occurs when users are given more permissions or access rights than necessary for their role. This happens when access control mechanisms fail to properly restrict user privileges. As a result, a normal user may perform administrative actions such as modifying system settings, accessing sensitive data, or managing other user accounts. Attackers can exploit this vulnerability to escalate privileges and gain unauthorized control over the system.

Business Impact

Improper privilege management can allow unauthorized users to access confidential data or perform critica administrative operations. This may lead to data breaches, financial loss, system manipulation, and operational disruption. In severe cases, attackers can gain full control of the system, damaging the organization’s reputation and causing compliance violations.

Vulnerability Path

User Login → Access Control System → Privilege Assignment → Sensitive Resource Access

Vulnerability Parameter

- User Role
- Access Permission Level
- Authorization Tokens
- Role-Based Access Control (RBAC) configuration
- Session privileges

STAGE-2

OVERVIEW:

Context-aware access control based on user identity ensures that system access is granted or restricted by verifying the user's identity and evaluating contextual factors such as device security, location, and application risk to enhance overall security.

1. Preparation:

The preparation phase involves identifying the assets, users, and security requirements of the system. Organizations must determine which applications, databases, and services require protection. User identities and roles such as administrators, employees, and external users should be defined clearly. Device posture requirements (updated OS, antivirus status, encryption) must also be identified. Trusted and untrusted locations should be defined, and application risk levels must be categorized based on sensitivity. Security policies and tools such as Identity and Access Management (IAM) and Multi-Factor Authentication (MFA) are planned in this stage.

2. Configuration:

In this phase, the access control system is configured according to the defined policies. User roles and permissions are created in the IAM system. Device posture checks are configured to ensure only secure devices can access the system. Location-based access rules are set to allow or restrict access from certain geographic areas or networks. Application risk levels are also configured so that high-risk applications require stronger authentication or additional verification.

3. Scanning:

Scanning involves monitoring and analyzing the system environment to verify whether access policies are correctly implemented. Automated security tools scan user login activities, device compliance status, network location, and application usage.

4. Vulnerability Identification**:**

During this phase, weaknesses in the access control system are identified. For example, the system may detect users accessing sensitive applications from unsecured devices, unknown locations, or without proper authentication.

5. Reporting:

After vulnerabilities are detected, a detailed report is generated. The report includes information such as the type of vulnerability, affected systems or applications, risk level, and possible impact. This report helps administrators understand the security status and prioritize fixes.

6. Remediation:

Remediation involves fixing the identified vulnerabilities. This may include updating security policies, enforcing stronger authentication, blocking access from untrusted locations, or requiring secure device compliance. System administrators implement these fixes to strengthen the access control system.

7. Follow-up: Regular Scanning:

Security monitoring should be continuous. Regular scanning ensures that new vulnerabilities are detected quickly. Scheduled security scans and monitoring tools help maintain the effectiveness of context-aware access control policies.

8. Compliance Auditing (if applicable):

Organizations may need to comply with security standards or regulations. Compliance auditing checks whether the implemented access controls meet required guidelines and policies. Auditors review logs, policies, and system configurations to ensure regulatory compliance.

S. No	Vulnerability Name	Severity	Plugins
1.	Weak Authentication Mechanism	High	Authentication Policy Check Plugin
2.	Access from Untrusted Location	Medium	-location Access Monitoring Plugin
3.	Unmanaged or Non-Compliant Device Access	High	Device Posture Assessment Plugin
4.	Missing Multi-Factor Authentication (MFA)	Critical	MFA Enforcement Plugin

Website: testfire.net Target

IP Address: 192.168.1.1

1.VULNERABILITY NAME: Weak Authentication Mechanism

SEVERITY**:** High

PLUGIN**:** Authentication Policy Check Plugin

PORT**:** 80 (HTTP) / 443 (HTTPS)

DESCRIPTION**:**

Weak authentication mechanisms occur when a system uses insecure or insufficient methods to verify user identity. This may include simple passwords, lack of password complexity rules, absence of account lockout policies, or failure to implement multi-factor authentication (MFA). Attackers can exploit weak authentication methods through techniques such as password guessing, brute-force attacks, or credential stuffing. If successful, unauthorized users may gain access to sensitive systems and data.

BUSINESS IMPACT:

Weak authentication can lead to unauthorized access to critical applications, confidential data leakage, and potential system compromise. This may result in financial losses, damage to the organization’s reputation, and violation of regulatory compliance requirements. In severe cases, attackers may gain administrative privileges and control over important business operations.

SOLUTION:

To mitigate weak authentication risks, organizations should implement strong password policies that enforce complexity, length, and periodic changes. Multi-Factor Authentication (MFA) should be enabled to add an additional layer of security.

2.VULNERABILITY NAME: Access from Untrusted location

SEVERITY: Medium

PLUGIN: Geo-location Access Monitoring Plugin

PORT: 443 (HTTPS) / 80 (HTTP)

DESCRIPTION:

This vulnerability occurs when users are able to access the system or application from unknown or untrusted geographic locations without proper verification. In context-aware access control systems, location should be used as a security factor to determine whether access is legitimate. If location-based restrictions are not implemented, attackers from different regions or suspicious networks may attempt unauthorized login to the system. This increases the risk of unauthorized access, especially if the login originates from locations where the organization does not normally operate.

BUSINESS IMPACT:

Allowing access from untrusted locations can expose the organization to security threats such as account compromise, unauthorized data access, and potential cyberattacks. Attackers may exploit stolen credentials to access sensitive business information from foreign or high-risk regions. This could lead to data breaches, financial losses, and damage to the organization's reputation.

SOLUTION:

To mitigate this vulnerability, organizations should implement location-based access control policies. Access should be allowed only from trusted locations such as corporate networks or approved regions. Suspicious login attempts from unknown locations should trigger additional verification steps like Multi-Factor Authentication (MFA). Security teams should also monitor login activity regularly and block access from high-risk geographic regions or anonymous networks such as VPNs or proxy servers when necessary.

3.VULNERABILITY NAME : Unmanaged or Non-Compliant Device Access

SEVERITY**:** High

PLUGIN**:** Device Posture Assessment Plugin

PORT: 443 (HTTPS) / 80 (HTTP)

DESCRIPTION:

This vulnerability occurs when users are allowed to access organizational systems or applications using devices that are not properly managed or do not meet security compliance requirements. Such devices may lack updated operating systems, antivirus protection, security patches, or encryption. Without device posture verification, attackers may use compromised or insecure devices to access sensitive systems. This weakens the overall security of the context-aware access control system.

BUSINESS IMPACT:

Allowing unmanaged or non-compliant devices to access business applications can lead to serious security risks. These devices may introduce malware, unauthorized data access, or system compromise. Sensitive company information could be exposed or stolen, which may result in financial loss, operational disruption, and damage to the organization's reputation. It may also lead to non-compliance with security standards and regulations.

SOLUTION:

Organizations should implement device posture verification before granting system access. Only devices that meet defined security standards—such as updated operating systems, active antivirus software, firewall protection, and encryption—should be allowed. Endpoint management tools and Mobile Device Management (MDM) solutions can be used to monitor device compliance. If a device does not meet security requirements, the system should restrict access or require remediation before access is granted.

4.VULNERABILITY NAME: Missing Multi-Factor Authentication (MFA)

SEVERITY:Critical

PLUGIN: MFA Enforcement Plugin

PORT: 443 (HTTPS) / 80 (HTTP)

DESCRIPTION:

Missing Multi-Factor Authentication (MFA) is a security vulnerability where the system relies only on a single authentication factor, usually a username and password, to verify user identity. Without MFA, attackers who obtain valid login credentials through phishing, brute-force attacks, or credential leaks can easily gain unauthorized access to the system. Since many web applications operate on ports **80 (HTTP)** and **443 (HTTPS)**, login services running on these ports become vulnerable if additional authentication factors such as OTP, biometrics, or authentication apps are not enforced.

BUSINESS IMPACT:

The absence of MFA significantly increases the risk of account compromise and unauthorized system access. Attackers may gain access to sensitive business data, confidential information, or administrative controls. This can lead to data breaches, financial losses, operational disruption, and damage to the organization's reputation. It may also cause non-compliance with security regulations and standards.

SOLUTION:

Organizations should implement **Multi-Factor Authentication (MFA)** for all critical systems and user accounts. MFA requires users to provide additional verification factors such as a one-time password (OTP), authentication app approval, biometric verification, or security tokens. This additional layer of security greatly reduces the risk of unauthorized access even if user credentials are compromised. Regular monitoring of login attempts and enforcing strong authentication policies can further strengthen system

STAGE-3

TITLE:

DESIGN AND APPLY CONTEXT-AWARE ACCESS CONTROLS BASED ON USER IDENTITY.

REPORT

1.INTRODUCTION:

Context-aware access control is a modern security approach that grants or restricts access to systems based on user identity and additional contextual factors. These factors may include device posture, user location, and application risk level. The goal is to ensure that only authorized users with trusted devices and environments can access sensitive resources. This approach improves security by dynamically evaluating each access request before granting permission.

2.OVERVIEW**:**

Context-aware access control based on user identity ensures that access to systems and applications is provided only after verifying the user's identity and analysing contextual conditions such as device security status, location, and application sensitivity.

3. OBJECTIVES:

- To verify user identity before granting system access.
- To ensure devices used for access meet security compliance requirements.
- To monitor user access based on geographic location and network trust.
- To protect sensitive applications based on risk level.
- To prevent unauthorized access and reduce security threats.

4. METHODOLOGY:

The system evaluates several factors before granting access:

- **User Identity:** Authentication through username, password, or identity management systems.
- **Device Posture:** Checking whether the device has updated security patches, antivirus, and proper configuration.
- **Location:** Verifying whether the login attempt is from a trusted or suspicious geographic location.
- **Application Risk:** Applying stricter security rules for high-risk or sensitive applications.

5. PROCESS STEPS:

Preparation:

Identify users, devices, and applications that require secure access control. Define security policies and requirements.

Configuration:

Configure identity and access management policies, device compliance checks, location restrictions, and application risk rules.

Scanning:

Use security scanning tools to analyze authentication systems, access policies, and system configurations.

Vulnerability Identification:

Detect weaknesses such as weak authentication, access from untrusted locations, unmanaged devices, or missing MFA.

Reporting:

Generate detailed reports that describe identified vulnerabilities, risk levels, and affected systems.

Remediation:

Fix vulnerabilities by strengthening authentication, enforcing device compliance, implementing MFA, and updating security policies.

Follow-up: Regular Scanning:

Perform periodic scans to detect new vulnerabilities and maintain security effectiveness.

Compliance Auditing:

Review access control policies and system logs to ensure compliance with security standards and organizational policies.

Documentation:

Maintain detailed documentation of policies, configurations, vulnerabilities, remediation steps, and audit results.

7. BUSINESS IMPACT:

If context-aware access controls are not implemented, organizations may face unauthorized system access, data breaches, financial losses, and reputational damage. Weak authentication and insecure devices can expose sensitive information and disrupt business operations.

8. SOLUTIONS AND RECOMMENDATIONS:

- Implement strong password policies.
- Enable Multi-Factor Authentication (MFA).
- Restrict access from untrusted locations.
- Enforce device posture verification.
- Use Identity and Access Management (IAM) systems.
- Continuously monitor login activities and security logs.

8.CONCLUSION:

Stage – 1 :

1. Context-aware access control improves system security by combining user identity with contextual factors.
2. It helps organizations manage access permissions more intelligently and prevent unauthorized access.
3. This approach supports modern security environments such as cloud systems, mobile devices, and remote work.

Stage – 2 :

1. Implementing context-aware access control helps identify and reduce security vulnerabilities in systems.
2. Security measures like MFA, device verification, and location checks strengthen access control policies.
3. Regular scanning, reporting, and remediation ensure continuous protection against security threats.

Stage – 3 :

1. Context-aware access control provides dynamic and flexible security by evaluating identity, device, location, and application risk.
2. It improves organizational security by reducing unauthorized access and protecting sensitive resources.
3. This approach supports modern **Zero Trust security models** and helps organizations maintain strong access management.

9.FUTURE SCOPE:

Stage – 1:

Future systems can integrate **AI-based risk analysis to automatically evaluate user identity, device posture, location, and application sensitivity for smarter access decisions.**

Stage – 2:

Organizations can enhance context-aware access control by implementing **advanced authentication methods such as biometrics, behavioral analysis, and automated threat detection.**

Stage – 3:

The system can be extended to support **Zero Trust Architecture, cloud environments, and IoT devices to provide stronger and more adaptive security for modern digital infrastructures.**

10.TOPICS EXPLORED:

1. **User Identity Verification** – Authenticating users before granting system access.
2. **Device Posture Check** – Ensuring the device meets required security standards.
3. **Location-Based Access** – Allowing access only from trusted locations or networks.
4. **Application Risk Control** – Applying stricter security for sensitive applications.
5. **Security Monitoring** – Continuously monitoring access activities to detect threats.

11.TOOLS EXPLORED:

1. Okta
2. Microsoft Azure Active Directory
3. Google BeyondCorp
4. Cisco Duo Security
5. Nessus
6 .Wireshark